Information Assurance and Security – ACIT4630

Iman Anooshehpour
Week 9

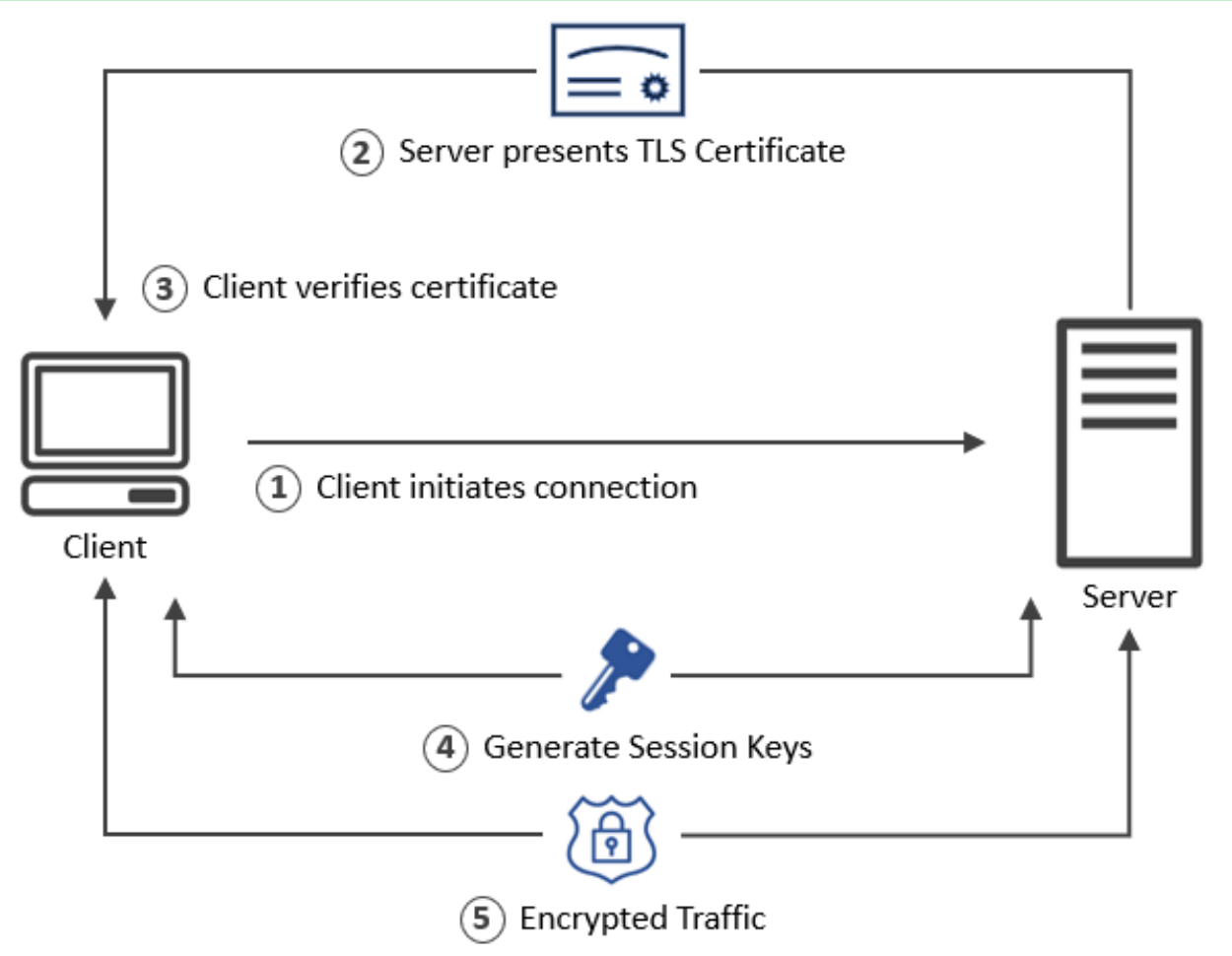
BRITISH COLUMBIA
INSTITUTE TECHNOLOGY

BCIT™

Learning Objectives

- ❑Explain the process of setting up a secure communication session using Transport Layer Security (TLS)
- ❑Highlight key improvements in TLS 1.3 over 1.2.
- ❑Summarize the Heartbleed bug's effect on OpenSSL and its consequences for internet security.
- ❑Identify key strategies to mitigate network vulnerabilities effectively.
- ❑Explain the concept of HSTS preloading and its role in enforcing secure connections

Transport Layer Security



Transport Layer Security

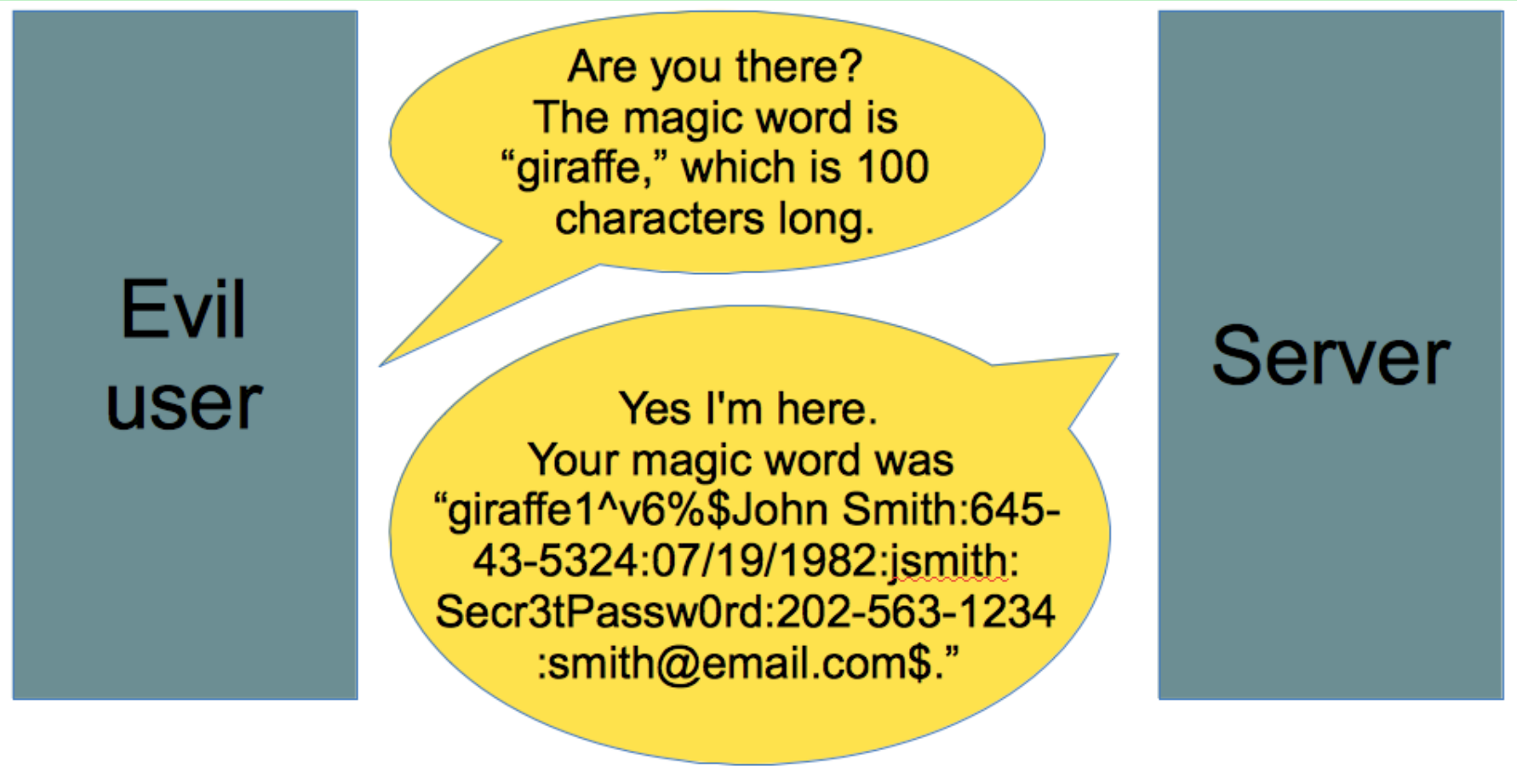
- TLS facilitates secure communication over public networks using **digital certificates** to exchange public encryption keys.
- Client and server negotiate to select a **cipher suite**, ensuring the encryption is as strong as the selected algorithms.
- TLS uses ephemeral keys, known as **session keys** (Symmetric keys), for encrypting communications, which are destroyed after each session.

Key Type	Used For
🔐 Asymmetric keys	Exchanging ephemeral session keys
🔑 Symmetric keys	Encrypting actual communication (ephemeral keys)

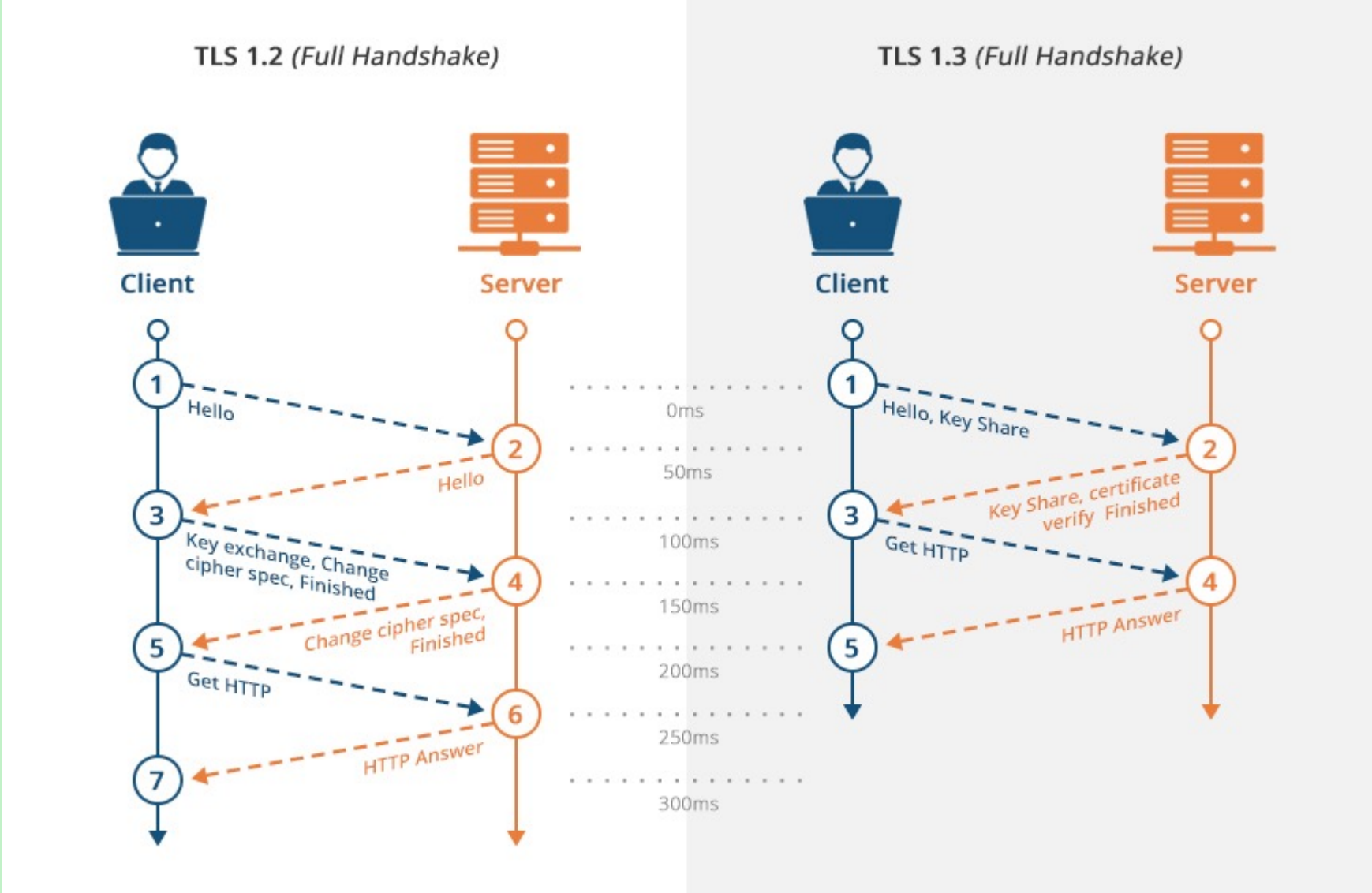
Detect and Block Malware: Inspect encrypted traffic for malicious content to prevent malware from entering the network.
Enforce Security Policies: Ensure compliance with organizational policies, such as blocking access to risky sites.
Prevent Data Leaks: Monitor for sensitive or proprietary data being sent outside the organization.

- Why would an organization perform a man-in-middle attack against its own users?

Heartbleed Bug



TLS 1.3


TLS 1.2 (Full Handshake)
Client
Server
1
Hello
2
Hello
3
Key exchange, Change cipher spec, Finished
4
Change cipher spec, Finished
5
Get HTTP
6
HTTP Answer
7
0ms
50ms
100ms
150ms
200ms
250ms
300ms
TLS 1.3 (Full Handshake)
Client
Server
1
Hello, Key Share
2
Key Share, certificate verify Finished
3
Get HTTP
4
HTTP Answer
5

Securing Common Protocols

- Use TLS to secure existing protocols:
  - HTTP → HTTPS
  - Telnet → SSH
  - FTP → FTPS & SFTP & SCP
  - RTP → SRTP
  - POP, IMAP, SMTP → use encrypted alternatives
  - DNS → DNSSEC
  - …

Network vulnerabilities

- Avoid using SSL and early versions of TLS; ensure your environment runs at least TLS 1.2.
- Ensure only secure cipher suites are supported for encryption to prevent vulnerabilities.
- Certificates should be current, properly signed by a reputable CA, and correctly named to avoid security gaps.
- Regularly update firmware and configure VPNs to use strong encryption protocols.
- Patch DNS servers regularly to protect against attacks due to open queries from outsiders.

HTTP Strict Transport Security

- HSTS is a security feature that ensures browsers only interact with websites over a secure HTTPS connection.
- The web server is configured to redirect all HTTP requests to HTTPS, ensuring data is encrypted during transit.
- HSTS Preloading is a mechanism to prevent even the first connection from being insecure by including the domain in a preloaded list of HTTPS-only sites.